

	FACULTAD DE INGENIERÍA EN SISTEMAS, ELECTRÓNICA E INDUSTRIAL	CÓDIGO: TI-SIGE-ENT-S3-003
	CARRERA DE INGENIERÍA DE SOFTWARE	VERSIÓN: 1.0
	PROCESO: DESARROLLO DE SOFTWARE / CIBERSEGURIDAD Y CONTROL DE ACCESO	ELABORACIÓN: 14/09/2026
	SEGURIDAD, AUTENTICACIÓN Y AUTORIZACIÓN (JWT & RBAC EN WEBAPI)	ÚLTIMA REVISIÓN: APROBADO POR LÍDER TÉCNICO

1. TÍTULO

Denominación del Entregable: Módulo de Seguridad: Autenticación Basada en Tokens JWT y Control de Acceso RBAC (.NET 9 WebAPI)

Ficha Técnica de Identificación:

- **Código Documental:** TI-SIGE-ENT-S3-003 — **Versión:** 1.0
- **Institución:** Universidad Técnica de Ambato (UTA) – FISEI
- **Carrera:** Ingeniería de Software (Séptimo Semestre .A'')
- **Módulo Académico:** Gestión de Proyectos de Software
- **Docente Tutor:** Ing. Paulo Torres
- **Fecha de Elaboración:** 14/09/2026 — **Estado:** **Completado / En Auditoría**
- **Período de Ejecución:** Semana 3 (09/09/2026 al 14/09/2026 – EDT 3.3: 4 días laborables, 32h)

2. INTRODUCCIÓN

La confidencialidad, trazabilidad y control de privilegios en el sistema **SIGE** exigen una arquitectura de seguridad robusta y sin estado (*stateless*). Dado que los docentes redactan información sensible y las autoridades emiten dictámenes oficiales con valor legal, la autenticación debe impedir accesos indebidos y garantizar el no repudio.

El estándar ****JSON Web Tokens (JWT)**** junto con el modelo de ****Control de Acceso Basado en Roles (RBAC)**** implementado en ASP.NET Core 9 permite autenticar solicitudes HTTP, transportar claims seguros (identificador de usuario, rol institucional y carrera asignada) y autorizar endpoints mediante políticas estrictas y atributos `[Authorize(Roles = "...")]`.

3. OBJETIVO

3.1. Objetivo General

Desarrollar el módulo de autenticación y autorización en la capa WebAPI de SIGE utilizando JWT y RBAC, blindando los endpoints contra accesos no autorizados y asegurando la segregación de funciones según los roles de la FISEI.

3.2. Objetivos Específicos

- Configurar el middleware de autenticación `JwtBearer` con firma simétrica HMAC-SHA256 y validación estricta de emisor (*Issuer*), audiencia (*Audience*) y tiempo de vida (*Lifetime*).

	FACULTAD DE INGENIERÍA EN SISTEMAS, ELECTRÓNICA E INDUSTRIAL	CÓDIGO: TI-SIGE-ENT-S3-003
	CARRERA DE INGENIERÍA DE SOFTWARE	VERSIÓN: 1.0
	PROCESO: DESARROLLO DE SOFTWARE / CIBERSEGURIDAD Y CONTROL DE ACCESO	ELABORACIÓN: 14/09/2026
	SEGURIDAD, AUTENTICACIÓN Y AUTORIZACIÓN (JWT & RBAC EN WEBAPI)	ÚLTIMA REVISIÓN: APROBADO POR LÍDER TÉCNICO

- Implementar el controlador AuthController con endpoints para inicio de sesión (/api/auth/login) y perfil de usuario autenticado (/api/auth/me).
- Definir políticas de autorización RBAC para restringir acciones críticas (dictámenes, habilitación extemporánea y circuito de firmas).

4. ALCANCE

4.1. Alcance Incluido

Generación de token JWT firmado con expiración de 120 minutos, claims de identidad (sub, email, role, carrera_id, nombre_completo), middleware global de captura de token en cabecera Authorization: Bearer <token> y pruebas de seguridad.

4.2. Límites y Exclusiones

No incluye autenticación federada externa con OAuth2 de Google Workspace en esta iteración.

5. DEFINICIONES

- **JWT (JSON Web Token):** Estándar abierto (RFC 7519) para transmitir información segura entre partes en formato JSON.
- **RBAC (Role-Based Access Control):** Mecanismo de restricción de accesos basado en las responsabilidades institucionales.

6. RESPONSABILIDADES

- **Nixon Hurtado (Backend / DBA):** Implementación de TokenService.cs y configuración de JwtBearer.
- **Steeven Toala (Líder / Arquitecto):** Definición de matrices de permisos y revisión de directivas de seguridad.
- **Ing. Paulo Torres (Docente Tutor):** Supervisión y validación del cumplimiento de directivas de seguridad.

7. NORMATIVA LEGAL Y TÉCNICA

- **Ley Orgánica de Protección de Datos Personales (Ecuador):** Confidencialidad y seguridad de información institucional.
- **OWASP Top 10 API Security Risks:** Mitigación de fallos de autenticación (API2) y autorización a nivel de objeto (API1).

	FACULTAD DE INGENIERÍA EN SISTEMAS, ELECTRÓNICA E INDUSTRIAL	CÓDIGO: TI-SIGE-ENT-S3-003
	CARRERA DE INGENIERÍA DE SOFTWARE	VERSIÓN: 1.0
	PROCESO: DESARROLLO DE SOFTWARE / CIBERSEGURIDAD Y CONTROL DE ACCESO	ELABORACIÓN: 14/09/2026
	SEGURIDAD, AUTENTICACIÓN Y AUTORIZACIÓN (JWT & RBAC EN WEBAPI)	ÚLTIMA REVISIÓN: APROBADO POR LÍDER TÉCNICO

8. MÉTODO, POLÍTICAS Y CONTENIDOS

Implementación basada en Microsoft ASP.NET Core Identity y Microsoft.AspNetCore.Authentication.JwtBearer. Se establecen políticas rigurosas de seguridad: se prohíbe transportar credenciales o hashes dentro del token JWT, se exige clave simétrica de 256 bits y se devuelven códigos HTTP 401 Unauthorized o 403 Forbidden según corresponda para peticiones no válidas.

9. DESCRIPCIÓN DE ACTIVIDADES

9.1. Estructura del Payload JWT Generado

Los tokens emitidos tras la autenticación exitosa contienen las declaraciones necesarias para la toma de decisiones descentralizada:

```
{
  "sub": "b1eebc99-9c0b-4ef8-bb6d-6bb9bd380b22",
  "email": "docente.software@uta.edu.ec",
  "role": "DOCENTE_RESPONSABLE",
  "carrera_id": "a0eebc99-9c0b-4ef8-bb6d-6bb9bd380a11",
  "nbf": 1726315200,
  "exp": 1726322400,
  "iss": "SIGE-UTA-AuthServer",
  "aud": "SIGE-ClientApp"
}
```

9.2. Endpoint /api/auth/login y Control de Acceso RBAC

Se implementó el controlador AuthController validando contraseñas mediante hash con sal y protegiendo las rutas con el atributo `[Authorize(Roles = "...")]`.

9.3. Matriz de Autorización RBAC en Endpoints

- POST /api/documentos: Restringido a DOCENTE_RESPONSABLE.
- POST /api/revisiones/dictamen: Restringido a autoridades evaluadoras.
- POST /api/administracion/habilitaciones: Exclusivo para ADMINISTRADOR.

9.4. Conclusiones y Recomendaciones Técnicas

- El esquema JWT + RBAC otorga desacoplamiento total entre el cliente frontend y la WebAPI, garantizando transacciones seguras y trazables.
- Los roles modelados corresponden de forma unívoca a la estructura académica del SGC de la FISEI UTA.

	FACULTAD DE INGENIERÍA EN SISTEMAS, ELECTRÓNICA E INDUSTRIAL	CÓDIGO: TI-SIGE-ENT-S3-003
	CARRERA DE INGENIERÍA DE SOFTWARE	VERSIÓN: 1.0
	PROCESO: DESARROLLO DE SOFTWARE / CIBERSEGURIDAD Y CONTROL DE ACCESO	ELABORACIÓN: 14/09/2026
	SEGURIDAD, AUTENTICACIÓN Y AUTORIZACIÓN (JWT & RBAC EN WEBAPI)	ÚLTIMA REVISIÓN: APROBADO POR LÍDER TÉCNICO

- Configurar HTTPS estricto con certificados SSL en ambientes de producción para evitar la interceptación del token en tránsito.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Nixon Hurtado <i>Backend Developer / DBA</i>	[FIRMADO DIGITALMENTE]	14/09/2026
Revisado por:	Steeven Toala <i>Líder de Proyecto / Arquitecto Software</i>		14/09/2026
Aprobado por:	Ing. Paulo Torres <i>Docente Tutor - Gestión Proyectos Software</i>	[PENDIENTE DE APROBACIÓN]	Pendiente

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Implementación de seguridad JWT y RBAC para Séptimo Semestre .A”	Nixon Hurtado	14/09/2026

12. ANEXOS

Anexo 1: Referencias Bibliográficas

- Internet Engineering Task Force (IETF). (2015). *RFC 7519: JSON Web Token (JWT)*.
- Microsoft Docs. (2026). *Authentication and authorization in ASP.NET Core Web APIs*.

Anexo 2: Matriz de Códigos de Retorno HTTP de Seguridad

- 200 OK: Autenticación exitosa y emisión de token JWT.
- 401 Unauthorized: Token ausente, firma inválida o expirado.
- 403 Forbidden: Token válido pero rol insuficiente para la operación solicitada.